

Firewall Behavior & Network Reconnaissance Lab Using pfSense

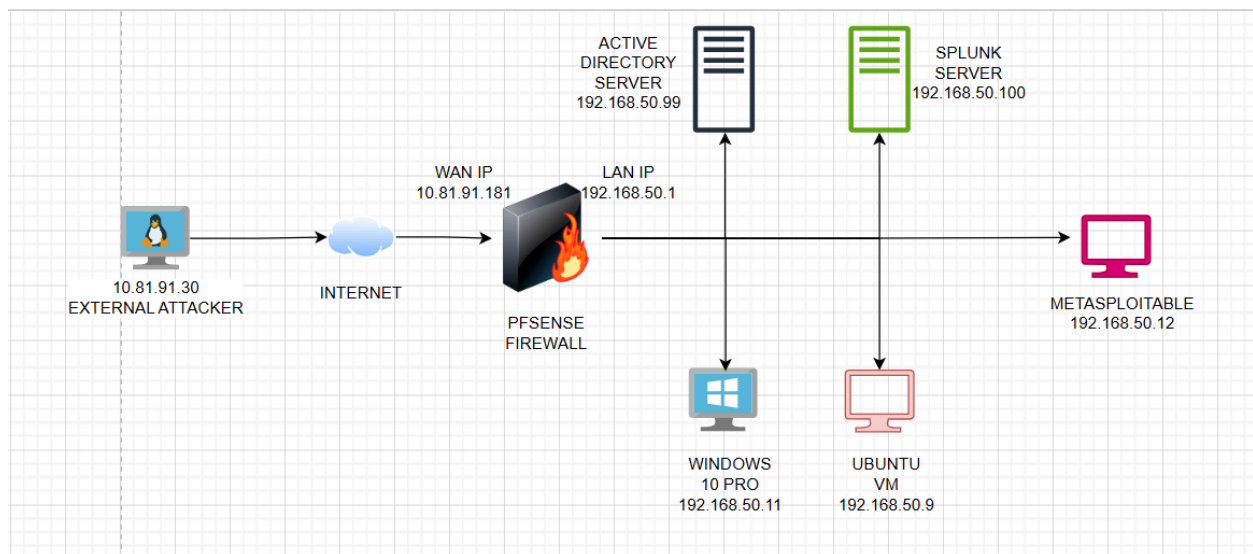
Project Summary

This project explores how firewall rules, static routing, and Network Address Translation (NAT) control communication between an external attacker (Kali Linux) and a protected internal network. I started with pfSense's default secure configuration, then intentionally weakened it step by step to observe the impact, and documented the fixes required to restore protection.

Objectives

- Understand default firewall behavior on WAN and LAN.
- Simulate external reconnaissance and controlled exposure of internal systems.
- Demonstrate the roles of firewall rules, routing, and NAT in bidirectional traffic.
- Highlight security risks of misconfiguration.

Lab Architecture



Lab Network Topology

The lab consists of a pfSense firewall acting as a perimeter defense between an external attacker (Kali Linux on the bridged network) and a protected internal network hosting an Active Directory environment.

- External Attacker: Kali Linux (10.81.91.30) – simulating threats from the internet.
- pfSense Firewall: WAN (10.81.91.181) | LAN (192.168.50.1)
- Internal Network (192.168.50.0/24):
 - Active Directory Domain Controller (192.168.50.99)
 - Windows 10 Pro (Domain Member) (192.168.50.11)
 - Ubuntu Server with Splunk (192.168.50.100)
 - Ubuntu VM (192.168.50.9)
 - Metasploitable (Vulnerable target) (192.168.50.12)

Note on IP Addressing

Due to the use of a bridged network adapter, both the pfSense WAN interface and Kali Linux receive their IP addresses dynamically from a home router via DHCP.

This causes the external IP addresses to change periodically (DHCP lease renewal). Some screenshots in this report display older IPs (e.g., 10.48.x.x , 10.35.x.x range), while others show newer IPs (e.g., 10.81.x.x range).

All concepts, firewall rules, routing configurations, and test results presented in this project are independent of the specific IP values and remain fully valid across IP changes.

WAN IP: 10.48.115.0/24, 10.35.168.0/24, 10.81.91.0/24

Phase 1: Baseline (Default Secure State)

pfSense was configured with standard settings: WAN on bridged adapter (external/untrusted), LAN on internal network (192.168.50.0/24 – trusted).

Tests from Kali (External):

```
ping <WAN IP>      # Failed
nmap -sS <WAN IP>  # Ports filtered
ping 192.168.50.1   # Failed
```

```
(kali㉿kali)-[~]
$ ping 10.48.115.181
PING 10.48.115.181 (10.48.115.181) 56(84) bytes of data.
From 10.48.115.30 icmp_seq=116 Destination Host Unreachable
From 10.48.115.30 icmp_seq=117 Destination Host Unreachable
From 10.48.115.30 icmp_seq=118 Destination Host Unreachable
From 10.48.115.30 icmp_seq=119 Destination Host Unreachable
From 10.48.115.30 icmp_seq=120 Destination Host Unreachable
From 10.48.115.30 icmp_seq=121 Destination Host Unreachable
From 10.48.115.30 icmp_seq=122 Destination Host Unreachable
From 10.48.115.30 icmp_seq=123 Destination Host Unreachable
From 10.48.115.30 icmp_seq=124 Destination Host Unreachable
^X^Z
zsh: suspended  ping 10.48.115.181
```

Icmp echo request to WAN IP unsuccessful

```
(kali㉿kali)-[~]
$ nmap -sS 10.35.168.181
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-18 10:18 EDT
Nmap scan report for 10.35.168.181
Host is up (0.0015s latency).
All 1000 scanned ports on 10.35.168.181 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:5E:29:FF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 22.56 seconds
```

Nmap to WAN IP unsuccessful

```
(kali㉿kali)-[~]
$ ping 192.168.50.1
ping: connect: Network is unreachable
```

Icmp echo request to LAN IP unsuccessful

Insight: pfSense enforces default-deny on WAN. No inbound traffic from external sources is allowed unless explicitly permitted.

Phase 2: Allowing Access to pfSense WAN IP

Added firewall rules on WAN:

- Pass ICMP Echo Request to This Firewall (self)
- Pass TCP to This Firewall (self)

Result: Ping and basic access to pfSense WAN IP now succeeded from Kali.

```
File Actions Edit View Help
(kali㉿kali)-[~]
$ ping 10.35.168.181
PING 10.35.168.181 (10.35.168.181) 56(84) bytes of data.
64 bytes from 10.35.168.181: icmp_seq=101 ttl=64 time=1.29 ms
64 bytes from 10.35.168.181: icmp_seq=102 ttl=64 time=1.99 ms
64 bytes from 10.35.168.181: icmp_seq=103 ttl=64 time=1.76 ms
64 bytes from 10.35.168.181: icmp_seq=104 ttl=64 time=1.55 ms
64 bytes from 10.35.168.181: icmp_seq=105 ttl=64 time=0.789 ms
64 bytes from 10.35.168.181: icmp_seq=106 ttl=64 time=1.84 ms
64 bytes from 10.35.168.181: icmp_seq=107 ttl=64 time=1.83 ms
64 bytes from 10.35.168.181: icmp_seq=108 ttl=64 time=1.63 ms
64 bytes from 10.35.168.181: icmp_seq=109 ttl=64 time=1.76 ms
64 bytes from 10.35.168.181: icmp_seq=110 ttl=64 time=0.917 ms
64 bytes from 10.35.168.181: icmp_seq=111 ttl=64 time=1.30 ms
64 bytes from 10.35.168.181: icmp_seq=112 ttl=64 time=1.95 ms
^Z
zsh: suspended ping 10.35.168.181

(kali㉿kali)-[~]
$ ping 192.168.50.1
PING 192.168.50.1 (192.168.50.1) 56(84) bytes of data.
^Z
zsh: suspended ping 192.168.50.1

(kali㉿kali)-[~]
$
```

Icmp echo request to pfsense WAN IP successful

```
(kali㉿kali)-[~]
$ nmap -sS -T4 10.35.168.181
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-18 12:56 EDT
Nmap scan report for 10.35.168.181
Host is up (0.0012s latency).
All 1000 scanned ports on 10.35.168.181 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:5E:29:FF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 22.18 seconds

(kali㉿kali)-[~]
$ nmap -sS -T4 10.35.168.181
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-18 13:03 EDT
Nmap scan report for 10.35.168.181
Host is up (0.0012s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
MAC Address: 08:00:27:5E:29:FF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.63 seconds
```

Nmap to pfsense WAN IP successful

☐	✓	0/0 B	IPv4 TCP	10.35.168.30	*	10.35.168.181	*	*	none	Allow TCP traffic from kali - lab testing only	
☐	✓	0/672 B	IPv4 ICMP	10.35.168.30	*	10.35.168.181	*	*	none	Allow ICMP Traffic from Kali - Lab testing only	
			<u>any</u>								

Firewall rules that allows Icmp and tcp traffic to WAN IP

Insight: Explicit rules are required to expose any service on the untrusted WAN side.

Phase 3: Attempting Access to Internal Network (Default Behavior)

- Attempted to ping the LAN default gateway (192.168.50.1) and internal devices from Kali.
- All attempts failed.

```
(kali㉿kali)-[~]  
$ ping 192.168.50.1  
PING 192.168.50.1 (192.168.50.1) 56(84) bytes of data.  
■
```

Icmp echo request to LAN IP unsuccessful

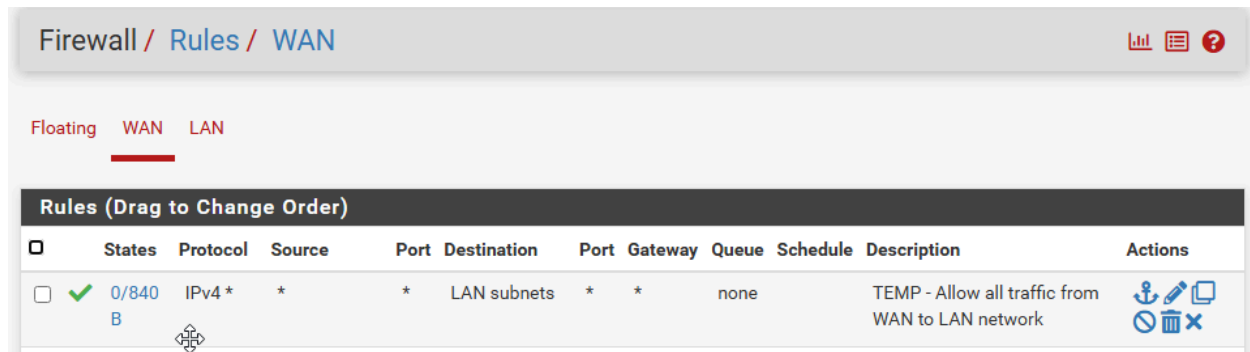
```
(kali㉿kali)-[~]  
$ ping 192.168.50.1  
ping: connect: Network is unreachable
```

Icmp echo request to LAN IP unsuccessful

Insight: Traffic from WAN to LAN subnet is blocked by default to protect the internal network.

Phase 4: Adding Static Route + Enabling WAN to LAN Traffic

- First, added a firewall rule on WAN:
 - Action: Pass
 - Protocol: Any
 - Source: Any
 - Destination: LAN net (192.168.50.0/24) or specifically the default gateway
 - Description: Allow traffic from WAN to LAN subnet / default gateway



Firewall rule that permits traffic from any source to the LAN network

- Still no success.
- Then, added a static route on Kali:

```
sudo ip route add 192.168.50.0/24 via <pfSense-WAN-IP>
```

Result: After adding the static route, Kali could:

- Ping the default gateway (192.168.50.1)
- Run Nmap against the gateway and internal devices

```
(kali㉿kali)-[~]
└─$ sudo ip route add 192.168.50.0/24 via 10.217.98.181
[sudo] password for kali:

(kali㉿kali)-[~]
└─$ ping 192.168.50.1
PING 192.168.50.1 (192.168.50.1) 56(84) bytes of data.
64 bytes from 192.168.50.1: icmp_seq=1 ttl=64 time=1.70 ms
64 bytes from 192.168.50.1: icmp_seq=2 ttl=64 time=1.73 ms
64 bytes from 192.168.50.1: icmp_seq=3 ttl=64 time=1.86 ms
^Z
zsh: suspended ping 192.168.50.1
```

```
(kali㉿kali)~[~]  
$ nmap -sS 192.168.50.1  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-30 15:44 EDT  
Nmap scan report for 192.168.50.1  
Host is up (0.0067s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
53/tcp    open  domain  
80/tcp    open  http  
443/tcp   open  https  
  
Nmap done: 1 IP address (1 host up) scanned in 5.14 seconds  
(kali㉿kali)~[~]
```

Nmap to pfsense LAN IP successful

Insight: Routing on the attacker side is necessary for packets to be sent toward the internal subnet, but it does not guarantee return traffic.

Phase 5: Identifying the Return Path Problem

- Internal devices received traffic.
- No responses came back to Kali (one-way communication).

Root Cause: Lack of proper return path / NAT for traffic initiated from the WAN side.

```
(kali㉿kali)-[~]  
$ nmap -sS -T4 192.168.50.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 05:32 EDT  
Nmap scan report for 192.168.50.1  
Host is up (0.0013s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
53/tcp    open  domain  
80/tcp    open  http  
443/tcp   open  https  
  
Nmap scan report for 192.168.50.2  
Host is up (0.0030s latency).  
All 1000 scanned ports on 192.168.50.2 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap done: 256 IP addresses (2 hosts up) scanned in 19.40 seconds
```

Nmap scan successful to just 192.168.50.1 & 2

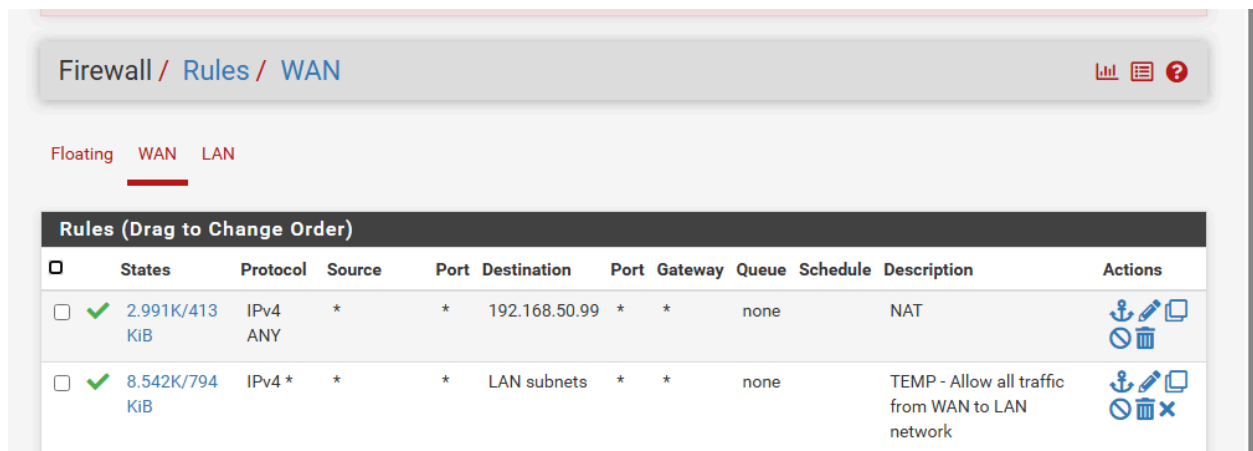
Phase 6: Phase 6: NAT Implementation

Action:

Configured NAT on pfSense to translate incoming WAN traffic

Result:

- Bidirectional ping and Nmap scans succeeded.
- Internal devices responded successfully
- Full discovery of internal hosts and open ports.



Firewall / Rules / WAN

Floating WAN LAN

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 2.991K/413 KiB	IPv4 ANY	*	*	192.168.50.99	*	*	none		NAT	
☐	✓ 8.542K/794 KiB	IPv4 *	*	*	LAN subnets	*	*	none		TEMP - Allow all traffic from WAN to LAN network	

NAT and firewall rule on WAN

Insight: NAT translates the source address of return traffic, enabling full communication when firewall rules permit it. A NAT rule was configured to translate incoming WAN traffic to a specific internal host (192.168.50.99). While this initially enabled successful communication with that host, a broader firewall rule allowing WAN-to-LAN traffic, combined with NAT-enabled return paths, allowed external scanning tools like Nmap to interact with multiple internal devices.

Phase 7: Network Reconnaissance

```
nmap -sS -T4 192.168.50.0/24
```

```
nmap -A 192.168.50.0/24
```

Before NAT: Hosts appeared down.

After NAT: Full host discovery and port scanning worked.

```
(kali㉿kali)-[~]  
$ nmap -sS -T4 192.168.50.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-01 04:14 EDT  
Nmap scan report for 192.168.50.1  
Host is up (0.0079s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
53/tcp    open  domain  
80/tcp    open  http  
443/tcp   open  https  
  
Nmap scan report for 192.168.50.2  
Host is up (0.013s latency).  
All 1000 scanned ports on 192.168.50.2 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap scan report for 192.168.50.11  
Host is up (0.015s latency).  
Not shown: 996 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
3389/tcp  open  ms-wbt-server
```

```
Nmap scan report for 192.168.50.12
Host is up (0.052s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
```

```

Nmap scan report for 192.168.50.99
Host is up (0.018s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman

```

```

Nmap scan report for 192.168.50.100
Host is up (0.010s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
8000/tcp  open  http-alt
8089/tcp  open  unknown

```

Nmap done: 256 IP addresses (6 hosts up) scanned in 16.31 seconds

```

kali@kali:~$ nmap -A 192.168.50.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-01 04:18 EDT
Nmap scan report for 192.168.50.1
Host is up (0.0030s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain (generic dns response: REFUSED)
80/tcp    open  http  nginx
|_ http-title: Did not follow redirect to https://192.168.50.1/
443/tcp   open  ssl/http nginx
|_ ssl-cert: Subject: commonName=pfSense-687e42ffd359b/organizationName=pfSense GUI default Self-Signed Certificate
|   Subject Alternative Name: DNS:pfSense-687e42ffd359b
|   Not valid before: 2025-07-21T13:39:12
|   Not valid after: 2026-08-23T13:39:12
|_ http-title: pfSense - Login
|_ ssl-date: TLS randomness does not represent time
|_ tls-alpn:
|   h2
|   http/1.1
|   http/1.0
|_ http/0.9
1 Service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.95XI=7XD=5/1KTime=69F461F6KP=x86_64-pc-linux-gnuXr(DNSVe
SF:rsionBindReqTCP,E,"0\x0c\0\x06\x81\x05\0\0\0\0\0\0\0");
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): FreeBSD 11.X (91%)
OS CPE: cpe:/o:freebsd:freebsd:11.2
Aggressive OS guesses: FreeBSD 11.2-RELEASE (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 53/tcp)
HOP RTT ADDRESS
1 6.61 ms 192.168.50.1

```

```

Nmap scan report for 192.168.50.11
Host is up (0.028s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
|_ ssl-date: 2026-05-01T16:20:21+00:00; +8h00m00s from scanner time.
|_ rdp-ntlm-info:
|   Target_Name: HOMELAB
|   NetBIOS_Domain_Name: HOMELAB
|   NetBIOS_Computer_Name: TARGET-PC1
|   DNS_Domain_Name: homelab.local
|   DNS_Computer_Name: Target-PC1.homelab.local
|   DNS_Tree_Name: homelab.local
|   Product_Version: 10.0.19041
|_ SystemTime: 2026-05-01T16:19:34+00:00
|_ ssl-cert: Subject: commonName=Target-PC1.homelab.local
|   Not valid before: 2026-02-28T15:55:02
|_ Not valid after: 2026-08-30T15:55:02
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 10|11|2019 (97%)
OS CPE: cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2019
Aggressive OS guesses: Microsoft Windows 10 1803 (97%), Microsoft Windows 10 1903 - 21H1 (97%), Microsoft Windows 11 (92%), Microsoft Windows 10 1909 (91%), Microsoft Windows 10 1909 - 20H2 (91%), Windows Server 2019 (91%), Microsoft Windows 10 1809 (91%), Microsoft Windows 10 20H2 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

```

Host script results:

```

|_ clock-skew: mean: 7h59m59s, deviation: 0s, median: 7h59m59s
|_ smb2-time:
|   date: 2026-05-01T16:19:35
|_ start_date: N/A
|_ smb2-security-mode:
|   3:1:1:
|_ Message signing enabled but not required

```

TRACEROUTE (using port 135/tcp)

```

HOP RTT      ADDRESS
-   Hop 1 is the same as for 192.168.50.12
2    175.32 ms 192.168.50.11

```

```

Nmap scan report for 192.168.50.12
Host is up (0.0059s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-syst:
|   STAT:
|_ FTP server status:
|   Connected to 10.81.91.30
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|_ vsFTPD 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
sslv2:
SSLv2 supported
ciphers:
SSL2_RC2_128_CBC_WITH_MD5
SSL2_DES_64_CBC_WITH_MD5
SSL2_RC4_128_WITH_MD5
SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
SSL2_DES_192_EDE3_CBC_WITH_MD5

```



```
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_ssl-date: 2026-05-01T08:20:18+00:00; -3s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp  open  domain          ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp  open  http            Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp  open  rpcbind         2 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000  2              111/tcp    rpcbind
|   100000  2              111/udp    rpcbind
|   100003  2,3,4          2049/tcp   nfs
|   100003  2,3,4          2049/udp   nfs
|   100005  1,2,3          54834/tcp  mountd
|   100005  1,2,3          60856/udp  mountd
|   100021  1,3,4          43812/tcp  nlockmgr
|   100021  1,3,4          48801/udp  nlockmgr
|   100024  1              49963/tcp  status
|   100024  1              52174/udp  status
139/tcp  open  netbios-ssn     Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn     Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec            netkit-rsh rshd
513/tcp  open  login           OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi        GNU Classpath grmiregistry
1524/tcp open  bindshell       Metasploitable root shell
2049/tcp open  nfs             2-4 (RPC #100003)
```

Key Findings

- Firewalls block inbound traffic from untrusted networks by default
- LAN networks are trusted and allow outbound communication
- Routing enables a device to reach other devices in another network but it doesn't guarantee a successful communication
- NAT enables communication when return paths are unavailable
- External reconnaissance depends on response traffic from the systems within a network.
- Misconfigured firewall or NAT rules can expose internal systems

Core Networking Model

1. Permission: The Firewall rule.

The WAN-to-LAN firewall rule acted as the primary enabler of inbound communication. By configuring a broad rule (e.g., source: any, destination: LAN net), the default behavior of pfSense which blocks unsolicited inbound traffic was overridden.

Result: External traffic from the attacker system was no longer dropped at the firewall and could enter the internal network.

2. Return Path: NAT as the "Return Address"

Even after allowing inbound traffic, communication initially failed because internal hosts lacked a valid return path to the external attacker. Internal devices received packets from an external IP (WAN side) and they had no direct route to respond to that external source. Network Address Translation (NAT) was then implemented on the firewall. NAT replaced the external source IP with an internal (LAN-side) IP. This made incoming traffic appear as if it originated from within the local subnet

Result: Internal devices responded to what appeared to be a local source. The firewall then translated those responses back to the original external IP.

3. Reachability: Why the Entire Network Became Visible

The attacker performed reconnaissance against a subnet range (e.g., 192.168.50.0/24) rather than a single host. The firewall, acting as the default gateway, was capable of forwarding traffic to any host within the internal subnet. The WAN-to-LAN rule allowed traffic to the entire LAN, not just a single device. NAT enabled bidirectional communication meaning that responses from multiple hosts could successfully return to the attacker.

Security Recommendations (How to Fix What Was Broken)

- Remove broad “Any to LAN net” rules immediately.
- Allow only specific ports/protocols needed.
- Enable Suricata on WAN for detection.
- Forward logs to Splunk.

Conclusion

This lab showed how small changes to firewall rules, routing, and NAT dramatically affect network security. Starting from a secure default, I intentionally broke pfsense to understand the risks, then identified the fixes. Proper configuration and least-privilege principles are essential when defending internal networks against external threats.

Skills Demonstrated

- Firewall rule configuration and analysis
- Network routing and troubleshooting
- NAT implementation
- Network reconnaissance using Nmap